امنیت در عصر عامل‌های هوشمند



+40000

https://javidnamaan.com



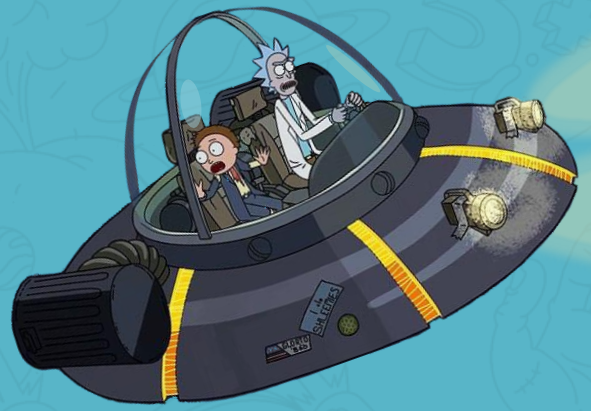


مجید ایرانپور

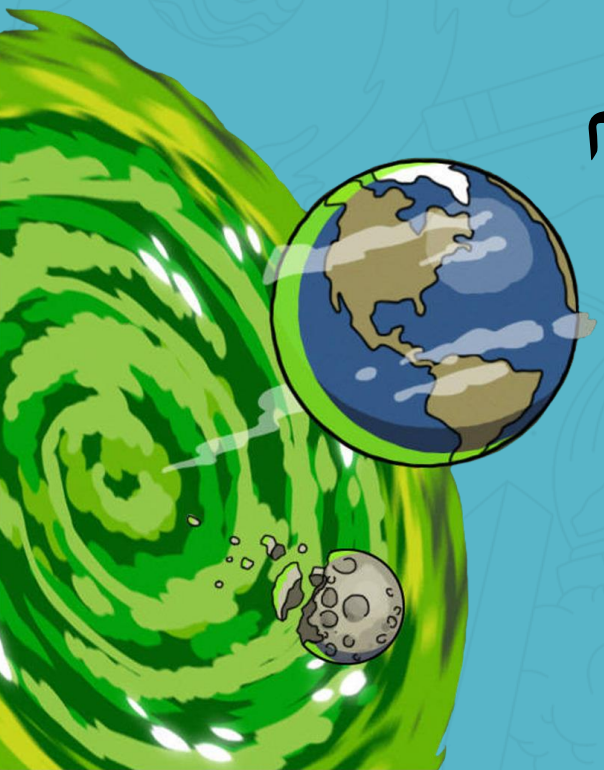
کارشناس امنیت اطلاعات / برنامه نویس / علاق مند به گنولینوکس

X / Twitter: @_majidmc2
Website : majidmc2.site

Telegram: @br34k_p01nt



بخش اول: ما اولین مسافران این قطار هستیم





دو مسیر موازی: نیم‌قرن تکامل دفاع و حمله



عصر LLM

۲۰۲۳ تا امروز



یادگیری ماشین

۲۰۱۲ به بعد



عصر الگوریتم

دهه ۱۹۹۰



تحلیل دستی

۱۹۷۱تا اواخر دهه ۸۰

stage_01.log

شروع بازی: تحلیل دستی در برابر کد دستی



چشم و دست کارشناس

- **هر فایل مشکوک را یک کارشناس، خط به خط، با چشم خودش بررسی می‌کرد و امضای آن را دستی می‌نوشت.**
- اولین شرکت‌های آنتی‌ویروس تجاری، از جمله سیمانتک در سال ۱۹۸۲و مک‌آفی در سال ۱۹۸۷، دقیقاً روی همین مدل بنا شدند؛ یک پایگاه‌داده از امضاهایی که انسان جمع می‌کرد.
- سرعت دفاع همان سرعت نوشتن انسان بود، نه بیشتر.

کد ثابت و یک‌بارنوشته

- **ویروس‌هایی مثل Creeper در سال ۱۹۷۱ و Brain در سال ۱۹۸۶ کاملاً دستی و خط‌به‌خط نوشته می‌شدند.**
- یک نسخه از کد برای همیشه همان کد باقی می‌ماند. هیچ تطبیق یا تغییری در حین اجرا نداشت.
- هدف فقط پخش شدن بود، نه فرار هوشمندانه از شناسایی.

وقتی الگوریتم جای انسان را گرفت



موتور تشخیص به‌جای چشم انسان

- **Snort در سال ۱۹۹۸توسط مارتین روش نوشته شد .نسخه اول آن فقط ۱۲۰۰خط کد بود.**
- تا سال ۲۰۰۱ بیش از ۴میلیون بار دانلود شده بود و به استاندارد جهانی تشخیص نفوذ تبدیل شد.
- شرکت Sourcefire که Snort را تجاری کرد، در سال ۲۰۱۳ به قیمت ۲.۷ میلیارد دلار به Cisco فروخته شد.

```
alert icmp any any -> any any (
    msg:"ICMP Ping Detected";
    itype:8;
    sid:1000001;
    rev:1;
)
```

کدی که خودش را تغییر می‌دهد

- **بدافزار چندریخت و فراریخت یاد گرفت خودش را در هر اجرا بازنویسی کند تا امضای ثابتی نداشته باشد.**
- کرم Conficker در سال ۲۰۰۸هر روز تا ۵۰هزار دامنه تصادفی برای تماس با سرور فرمان خود می‌ساخت؛ عملاً غیرقابل مسدود کردن.
- در اوج خود، این کرم تا ۱۰میلیون دستگاه را آلوده کرده بود.

stage_02.log
stage_03.log

دفاع یاد می‌گیرد: یادگیری ماشین و داده‌کاوی

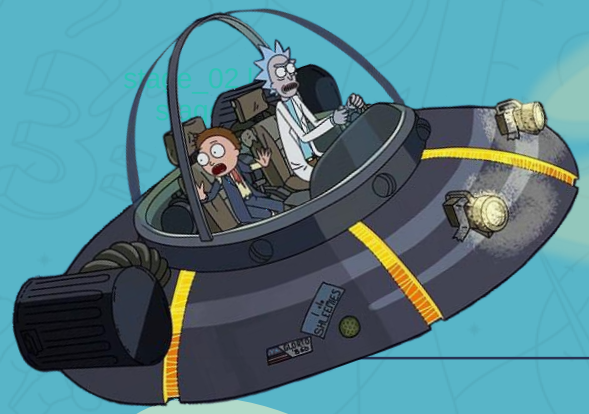
مدل‌هایی که رفتار را پیش‌بینی می‌کنند

- **Cylance که در سال ۲۰۱۲ تاسیس شد، شعارش این بود: آنتی‌ویروس بدون امضا به‌جای امضا، رفتار فایل را با یادگیری ماشین پیش‌بینی می‌کرد.**
- **Darktrace** که در سال ۲۰۱۳در کمبریج تاسیس شد، مفهوم سیستم ایمنی سازمانی را معرفی کرد؛ یادگیری بدون‌نظارت از رفتار عادی هر سازمان.

بدافزار به‌عنوان یک سرویس

- **بدافزار و فیشینگ به‌صورت اشتراکی در فوروم‌های زیرزمینی خرید و فروش شد .کافی بود پول بدهی تا صاحب یک حمله آماده شوی.**
- کیت‌های بهره‌برداری خودکار، مثل **Blackhole Exploit Kit**، حمله در مقیاس را حتی برای افراد کم‌تجربه ممکن کردند.
- برای اولین‌بار، کسی که کد مخرب را می‌نوشت لزوماً همان کسی نبود که از آن استفاده می‌کرد.





اکنون: هوش مصنوعی به‌جای انسان فکر می‌کند

پشت فکر تحلیل‌گر می‌نشیند

- **Microsoft Security Copilot در مارس ۲۰۲۳معرفی شد؛ ترکیب GPT-4 با مدل امنیتی اختصاصی مایکروسافت و بیش از ۶۵تریلیون سیگنال روزانه.**
- طبق داده‌های مایکروسافت، سازمان‌هایی که از آن استفاده کرده‌اند نزدیک به ۳۰٪ کاهش در زمان پاسخ به رخداد گزارش داده‌اند.
- تحلیل‌گر امنیتی دیگر خودش زنجیره تحلیل را نمی‌سازد .سوال می‌پرسد و هوش مصنوعی پاسخ و منطق پشت آن را تحویل می‌دهد.

فقط هدف بده، مدل خودش هک می‌کند

- **WormGPTو FraudGPT در سال ۲۰۲۳ نشان دادند یک مدل زبانی، بدون هیچ محدودیتی، می‌تواند بدافزار، ایمیل فیشینگ و اسکریپت حمله را فقط از یک دستور ساده بسازد.**
- دیگر لازم نیست مهاجم کدنویس باشد .کافی است هدف را توصیف کند.
- گام بعدی این مسیر، عامل‌هایی هستند که خودشان کد می‌زنند، اجرا می‌کنند و در لحظه تطبیق می‌دهند؛ موضوعی که چند اسلاید بعد با جزئیات کامل می‌بینیم.

هوش مصنوعی فقط پیدا نمی‌کند، نفوذ می‌کند

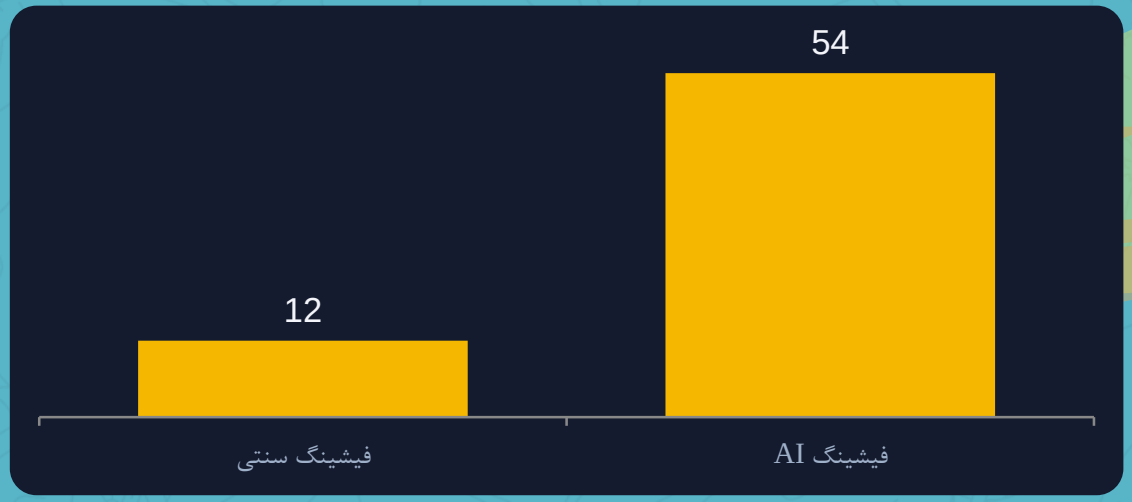
- **Infosecurity Europe: Mythos Outperforms GPT5.5 on Google Chrome Vulnerability Exploits, Says New Benchmark**
  - www.infosecurity-magazine.com/news/mythos-gpt-chrome-exploits
- **OpenAI and Hugging Face partner to address security incident during model evaluation**
  - https://openai.com/index/hugging-face-model-evaluation-security-incident



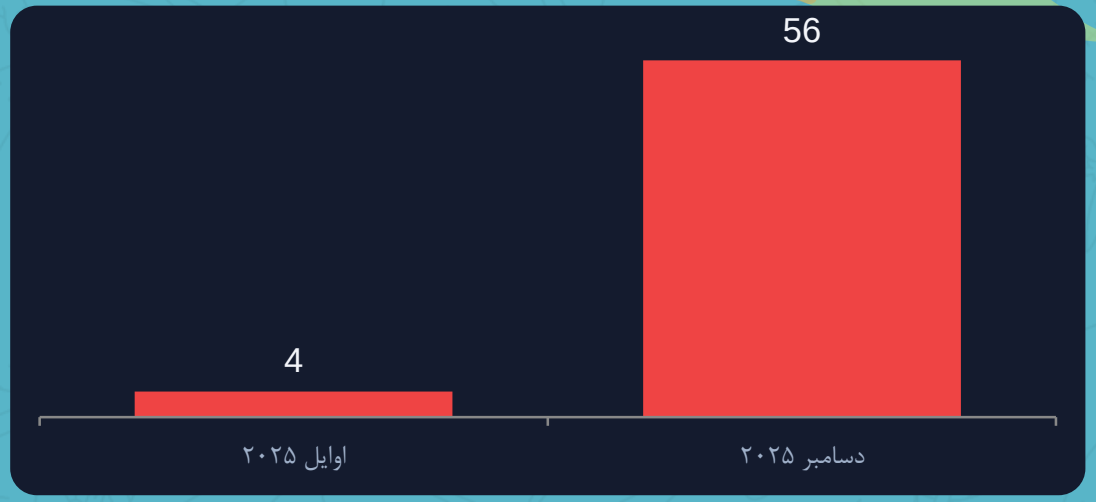
phishing_stats.csv

موج فیشینگ تولیدشده با هوش مصنوعی

نرخ کلیک فیشینگ AI در برابر فیشینگ سنتی



سهم فیشینگ تولیدشده با AI



$۷۵

هزینه راه‌اندازی یک کمپین فیشینگ مبتنی بر AI

×۱۴

جهش سهم فیشینگ AI محور طی یک ماه، دسامبر ۲۰۲۵

٪۸۲.۶

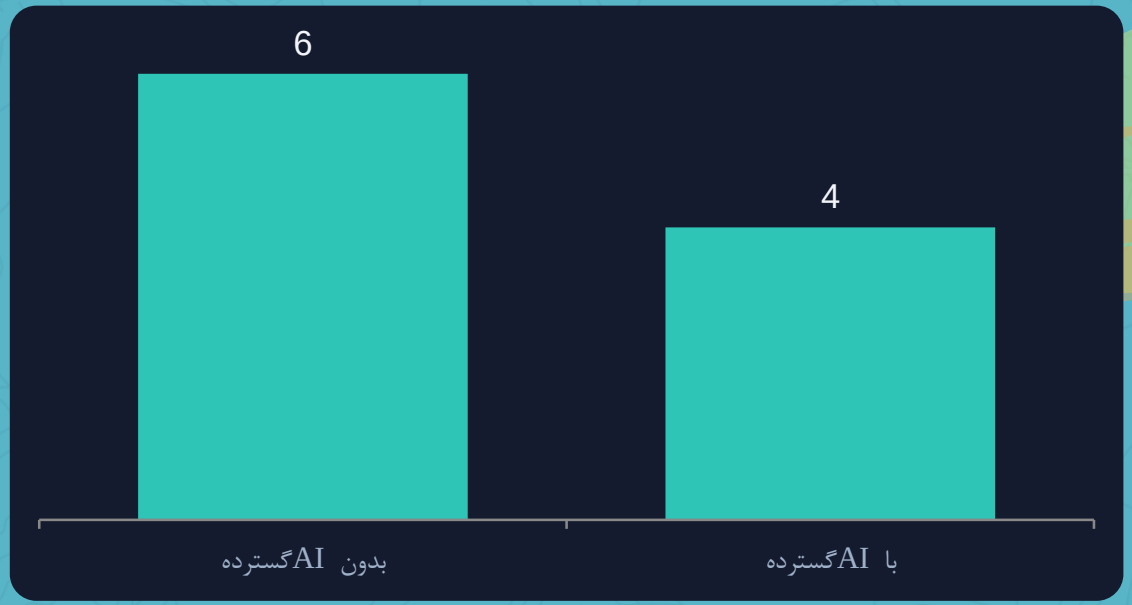
ایمیل‌های فیشینگ بین سپتامبر ۲۰۲۴و فوریه ۲۰۲۵از AI استفاده کرده‌اند

Zensec (Keepnet/VIPRE) ،StationX Phishing Statistics 2026 ؛ Hoxhunt Phishing Trends Report 2026

ibm_report.json

دفاع هم هوشمند می‌شود: هوش مصنوعی در مرکز عملیات امنیت

میانگین هزینه نشت داده (میلیون دلار)



- **سازمان‌هایی که هوش مصنوعی و اتوماسیون امنیتی را به‌طور گسترده به‌کار می‌گیرند، به‌طور میانگین ۱.۹میلیون دلار در هر رخداد نشت داده صرفه‌جویی می‌کنند.**
- میانگین جهانی هزینه نشت داده در سال ۲۰۲۵برای اولین‌بار در پنج سال گذشته ۹٪ کاهش یافت

۸۰روز

کوتاه‌تر شدن چرخه شناسایی و مهار نشت داده

عامل‌های خودمختار وارد میدان دفاع می‌شوند

+۱٬۰۶۰

آسیب‌پذیری گزارش‌شده

#۱

رتبه جهانی **HackerOne**

$۱۸ / $۶۰

هزینه ساعتی؛ **AI** در برابر انسان

۲۸دقیقه

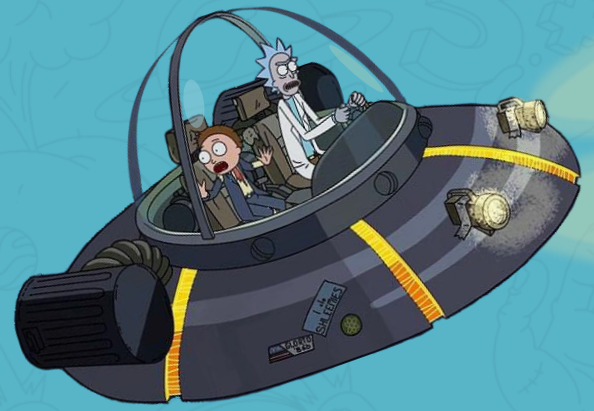
معادل یک ارزیابی ۴۰ ساعته انسانی

- **در ژوئیه ۲۰۲۵، XBOW، یک پن‌تستر کاملاً خودکار مبتنی بر AI، برای اولین‌بار در تاریخ باگ‌بانتی رتبه یک جدول HackerOneآمریکا را کسب کرد؛ بالاتر از هزاران هکر انسانی.**
- بدون دخالت انسان در حین اجرا، زنجیره‌های بهره‌برداری تا ۴۸مرحله را به‌طور خودکار کشف و اجرا می‌کند.
- مرز میان ابزار دفاعی و هکر خودمختار هر روز کم‌رنگ‌تر می‌شود.

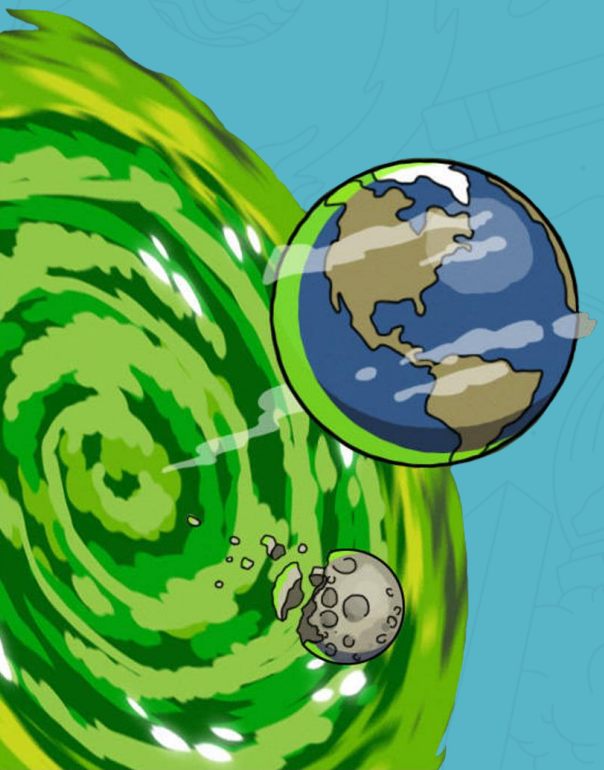
بازی موش و گربه هرگز تمام نمی‌شود



- **دفاع مسیر تحلیل دستی، الگوریتم و IDS، یادگیری ماشین و در نهایت LLMرا طی کرد .حمله هم‌زمان مسیر کد دستی، کد خودتطبیق، اتوماسیون و عامل هدف‌محور را رفت :دو خط موازی که هر جهش یکی، جهش بعدی دیگری را متولد کرد.**
- تفاوت امروز با دیروز سرعت است نه دیگر ماه‌ها و هفته‌ها، بلکه دقیقه‌ها و ثانیه‌ها.
- برای متخصصان امنیت، تسلط بر ابزارهای دفاعی مبتنی بر هوش مصنوعی دیگر یک انتخاب نیست، شرط بقا در این بازی است.



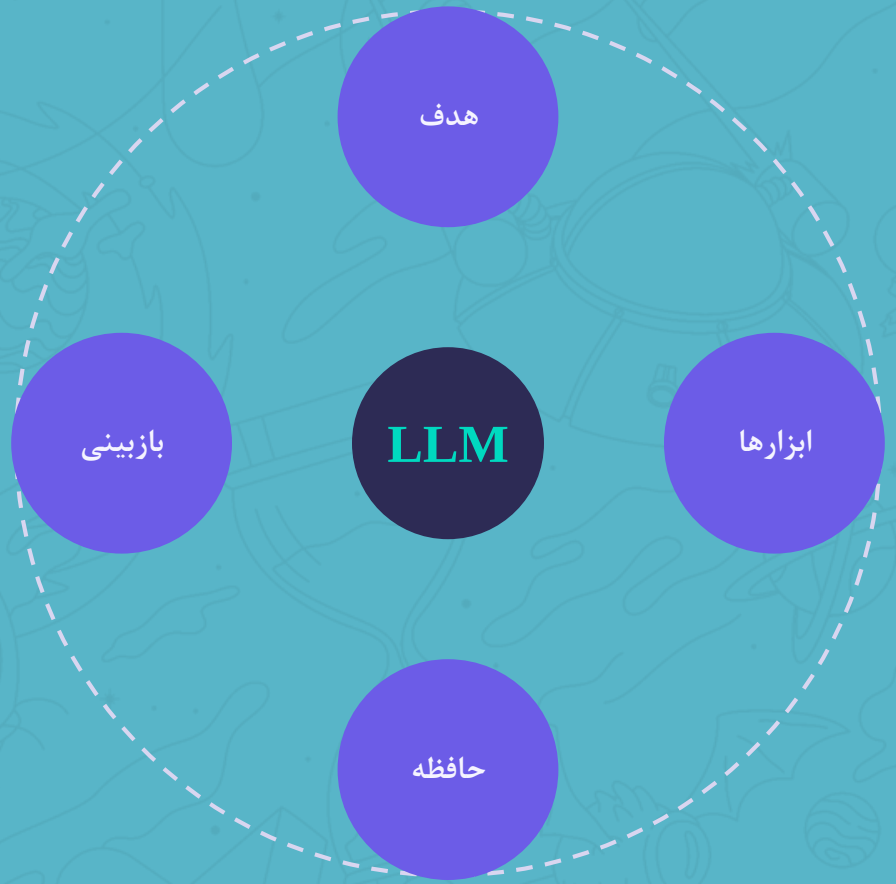
بخش دوم: شروع کن





عامل هوش مصنوعی (AI Agent)

عامل هوش مصنوعی سامانه‌ای است که با اتکا به یک مدل زبانی بزرگ، به‌صورت مستقل هدف را درک می‌کند، برای رسیدن به آن برنامه‌ریزی می‌کند، از ابزارها و منابع بیرونی استفاده می‌کند و بر اساس بازخورد محیط، مسیر خود را اصلاح می‌کند.



از چت‌بات تا عامل خودمختار

1

چت‌بات قانون‌محور

پاسخ‌های از پیش تعریف‌شده، بدون درک زمینه

2

دستیار مبتنی بر LLM

- مکالمه طبیعی، بدون اتصال به ابزار یا حافظه
- منفعل هستند
- WorkFlow

3

عامل مجهز به ابزار

- فراخوانی API، جست‌وجو، اجرای کد
- دسترسی به داده های شما

4

عامل خودمختار چندمرحله‌ای

برنامه‌ریزی، حافظه بلندمدت، اصلاح خطا

5

سیستم چندعاملی

همکاری چند عامل تخصصی با یک هماهنگ‌کننده

LLM

حافظه

- رفتار و دستور العمل Skill
- گفت و گوی فعلی-ناپایدار
- تاریخچه اتفاقات
- وضعیت کاربر



مهندسی حلقه یا Loops



- Prompt کاربر بر خلاف چت معمولی مشخص باشد

هدف / محدودیت / خروجی / شکست

- شرط توقف برای پایان کار یک عامل هوشمند همواره باید شفاف باشد

۱- ردیابی

۲- ارزیابی

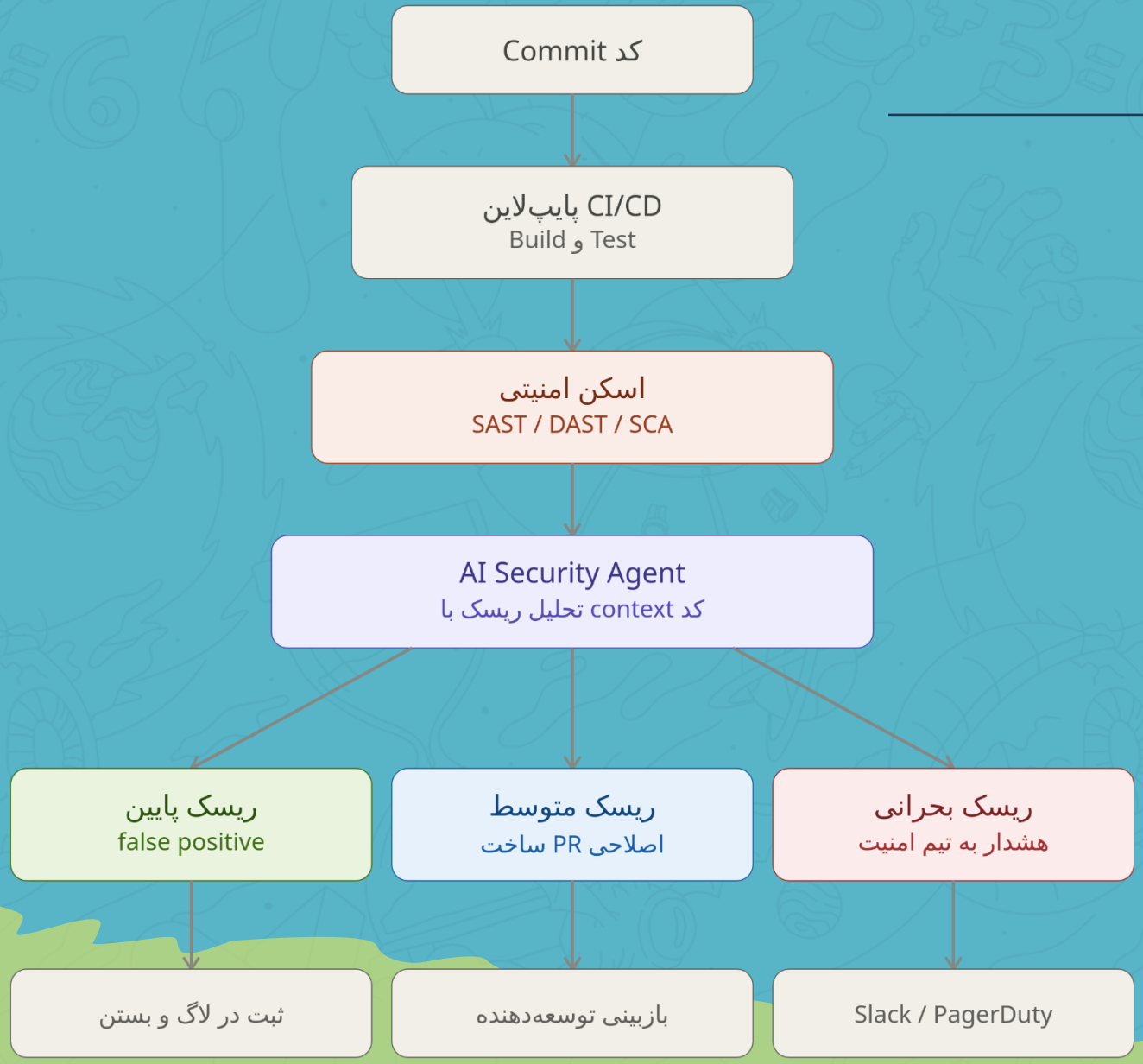
۳- اصلاح

فراخوانی ابزار و پروتکل MCP

پروتکل Model Context Protocol (MCP) یک استاندارد باز برای اتصال عامل‌های هوش مصنوعی به ابزارها، داده‌ها و سرویس‌های بیرونی است؛ بدون نیاز به یکپارچه‌سازی سفارشی برای هر ابزار.



هی چیزی بهتر از یک مثال نیست!



از کجا شروع کنم؟



Hermes

- پشتیبانی از مدل‌های مختلف
  - OpenAI, Pllama, Openrouter, …
- اجرای ابزارها، اسکریپت‌ها و API ها
- اجرای دستورات Shell و تعامل با سیستم‌عامل
- خواندن، تحلیل و ویرایش فایل‌ها و پروژه‌های کدنویسی
- Agent های چندمرحله‌ای (Planning + Reasoning + Execution)
- معماری قابل توسعه و افزودن ابزارهای سفارشی
- مناسب برای خودکارسازی Workflow
- کاملاً متن‌باز و قابل اجرا روی سیستم شخصی (Self-hosted)

WUBBA LUBBA DUB DUB!